

Password Cracking: Hashcat e John the Ripper

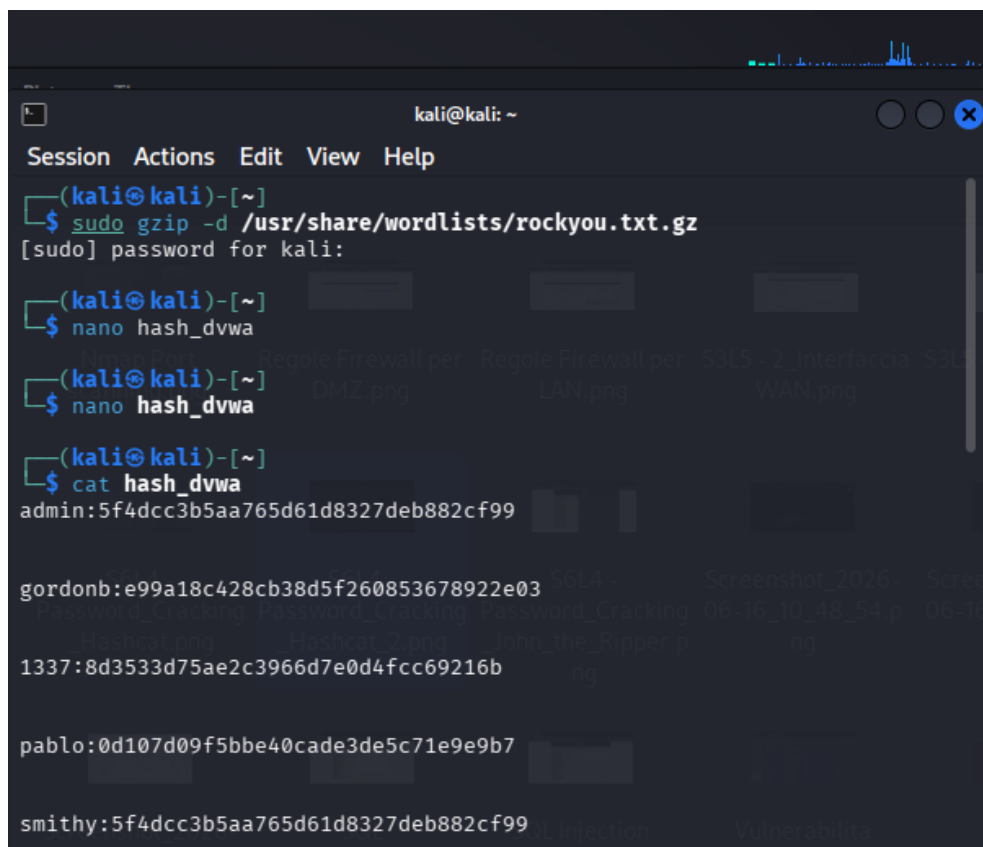
Esercitazione pratica su hash estratti da DVWA (SQL Injection)

Introduzione

L'attività ha avuto l'obiettivo di estrarre e successivamente crackare una serie di hash di password ottenuti tramite una vulnerabilità di SQL Injection presente nell'applicazione DVWA (Damn Vulnerable Web Application). Gli hash, in formato MD5, sono stati sottoposti ad attacco a dizionario utilizzando due dei principali strumenti di password cracking: **Hashcat** e **John the Ripper**, entrambi eseguiti su Kali Linux.

1. Estrazione degli hash

Prima dell'estrazione è stato necessario decomprimere la wordlist RockYou (rockyou.txt.gz), che verrà usata come dizionario per l'attacco, e creare/verificare il file degli hash con i comandi nano e cat.



```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ sudo gzip -d /usr/share/wordlists/rockyou.txt.gz  
[sudo] password for kali:  
(kali@kali)-[~]  
$ nano hash_dvwa  
(kali@kali)-[~]  
$ nano hash_dvwa  
(kali@kali)-[~]  
$ cat hash_dvwa  
admin:5f4dcc3b5aa765d61d8327deb882cf99  
  
gordonb:e99a18c428cb38d5f260853678922e03  
  
1337:8d3533d75ae2c3966d7e0d4fcc69216b  
  
pablo:0d107d09f5bbe40cade3de5c71e9e9b7  
  
smithy:5f4dcc3b5aa765d61d8327deb882cf99
```

Figura 1 – Decompressione della wordlist rockyou.txt e creazione del file hash_dvwa contenente gli hash estratti

Successivamente, gli hash delle password sono stati recuperati sfruttando la vulnerabilità SQL Injection della pagina "User ID" di DVWA e salvati in locale in un file di testo chiamato hash_dvwa.txt, nel formato utente:hash (uno per riga). Sono stati recuperati 4 account con relativo hash MD5.

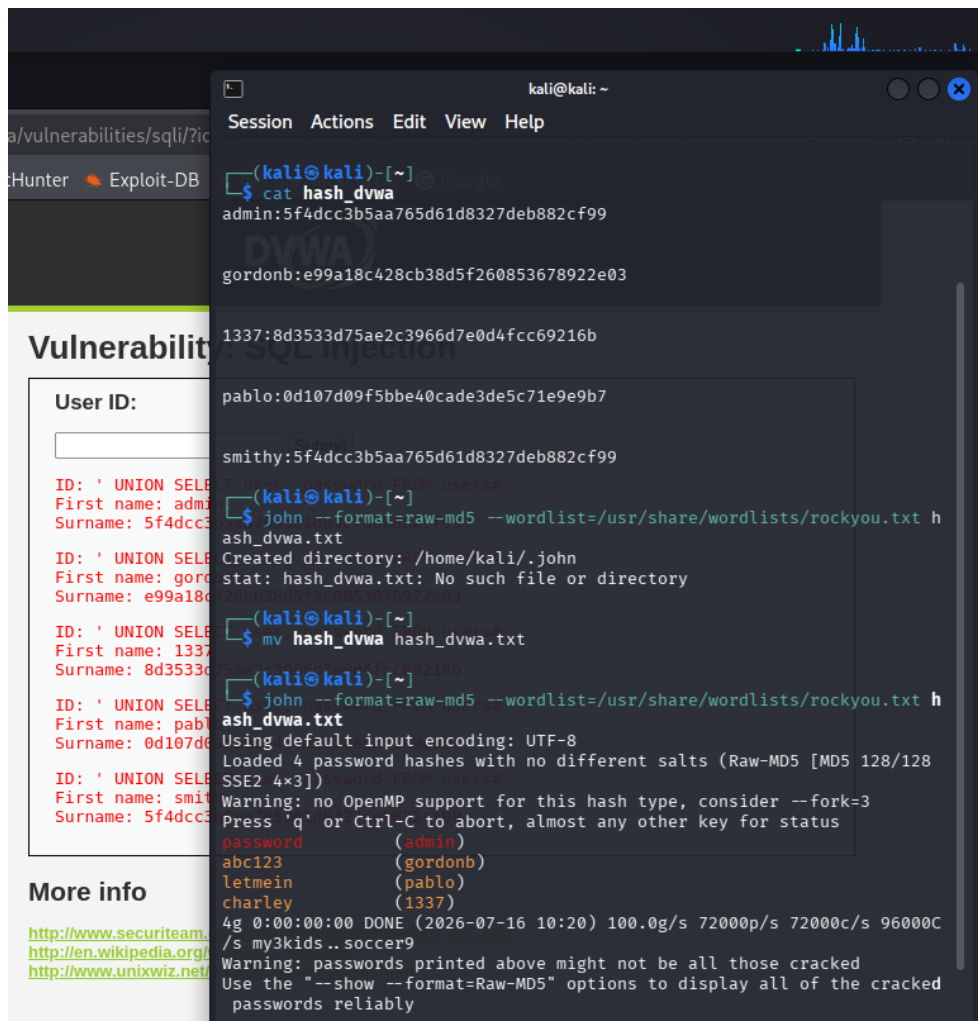


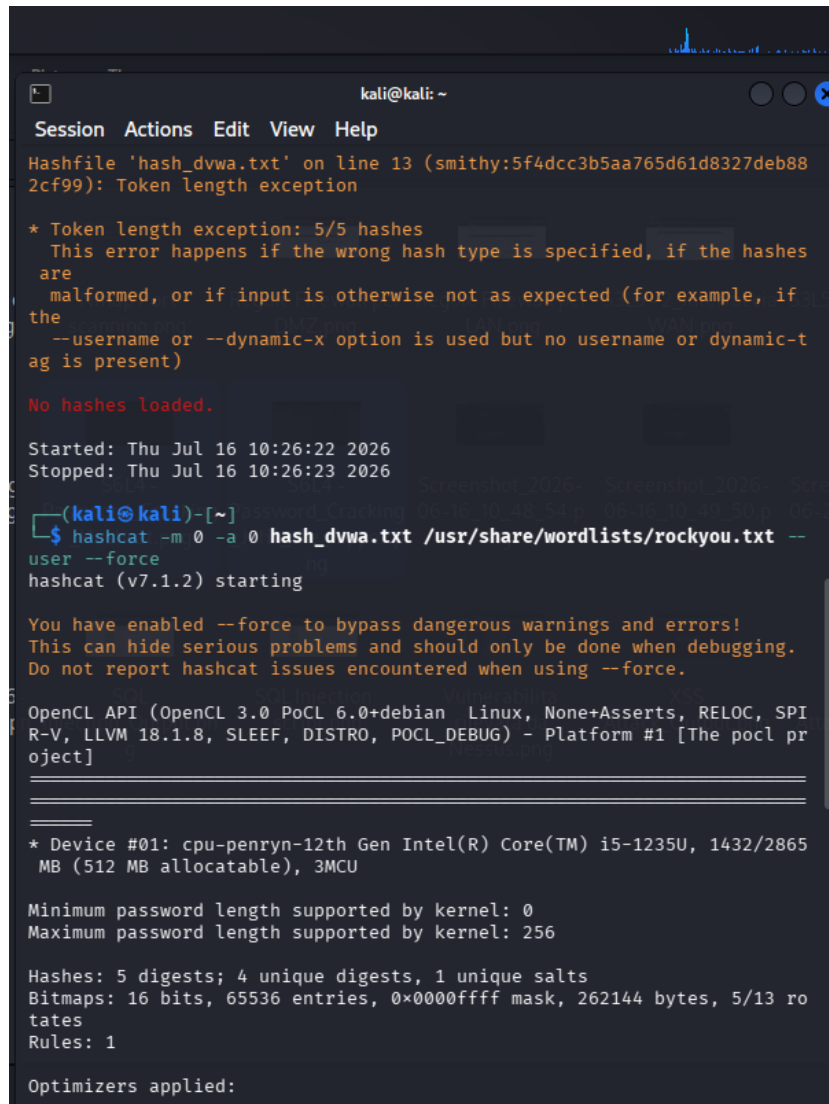
Figura 2 – Pagina di SQL Injection di DVWA e contenuto del file hash_dvwa.txt con gli hash estratti

2. Cracking con Hashcat

Il primo tentativo è stato effettuato con Hashcat, specificando la modalità di attacco a dizionario (-a 0) e il tipo di hash MD5 (-m 0), utilizzando la wordlist RockYou come dizionario:

```
hashcat -m 0 -a 0 hash_dvwa.txt /usr/share/wordlists/rockyou.txt --force
```

Un primo tentativo, eseguito con un file contenente 5 hash, ha generato un errore ("Token length exception") a causa della presenza di un hash malformato o di lunghezza non corretta in una delle righe del file. È stato quindi necessario correggere/verificare il file degli hash prima di rilanciare l'attacco.



```
kali@kali: ~  
Session Actions Edit View Help  
Hashfile 'hash_dvwa.txt' on line 13 (smithy:5f4dcc3b5aa765d61d8327deb882cf99): Token length exception  
  
* Token length exception: 5/5 hashes  
  This error happens if the wrong hash type is specified, if the hashes are malformed, or if input is otherwise not as expected (for example, if the --username or --dynamic-x option is used but no username or dynamic-tag is present)  
  
No hashes loaded.  
  
Started: Thu Jul 16 10:26:22 2026  
Stopped: Thu Jul 16 10:26:23 2026  
  
(kali@kali)-[~]  
$ hashcat -m 0 -a 0 hash_dvwa.txt /usr/share/wordlists/rockyou.txt --user --force  
hashcat (v7.1.2) starting  
  
You have enabled --force to bypass dangerous warnings and errors!  
This can hide serious problems and should only be done when debugging.  
Do not report hashcat issues encountered when using --force.  
  
OpenCL API (OpenCL 3.0 PoCL 6.0+debian Linux, None+Asserts, RELOC, SPIR-V, LLVM 18.1.8, SLEEF, DISTRO, POCL_DEBUG) - Platform #1 [The pocl project]  
  
* Device #01: cpu-penryn-12th Gen Intel(R) Core(TM) i5-1235U, 1432/2865 MB (512 MB allocatable), 3MCU  
  
Minimum password length supported by kernel: 0  
Maximum password length supported by kernel: 256  
  
Hashes: 5 digests; 4 unique digests, 1 unique salts  
Bitmaps: 16 bits, 65536 entries, 0x0000ffff mask, 262144 bytes, 5/13 rotates  
Rules: 1  
  
Optimizers applied:
```

Figura 3 – Errore di Hashcat dovuto a un hash malformato nel file di input

Corretto il file, Hashcat ha costruito la cache del dizionario RockYou (oltre 14 milioni di password) e ha portato a termine con successo l'attacco, individuando in pochi secondi tutte le password corrispondenti agli hash MD5 forniti (4 su 4 hash recuperati):

```
5f4dcc3b5aa765d61d8327deb882cf99 : password  
e99a18c428cb38d5f260853678922e03 : abc123  
0d107d09f5bbe40cade3de5c71e9e9b7 : letmein  
8d3533d75ae2c3966d7e0d4fcc69216b : charley
```

```
kali@kali: ~  
Session Actions Edit View Help  
ne.  
See the above message to find out about the exact limits.  
Watchdog: Temperature abort trigger set to 90c  
Host memory allocated for this attack: 512 MB (1603 MB free)  
Dictionary cache building /usr/share/wordlists/rockyou.txt: 33553434 by  
Dictionary cache built:  
* Filename..: /usr/share/wordlists/rockyou.txt  
* Passwords.: 14344392  
* Bytes.....: 139921507  
* Keyspace..: 14344385  
* Runtime ...: 0 secs  
5f4dcc3b5aa765d61d8327deb882cf99:password  
e99a18c428cb38d5f260853678922e03:abc123  
0d107d09f5bbe40cade3de5c71e9e9b7:letmein  
8d3533d75ae2c3966d7e0d4fcc69216b:charley  
Session.....: hashcat  
Status.....: Cracked  
Hash.Mode.....: 0 (MD5)  
Hash.Target.....: hash_dvwa.txt  
Time.Started.....: Thu Jul 16 10:28:54 2026, (0 secs)  
Time.Estimated...: Thu Jul 16 10:28:54 2026, (0 secs)  
Kernel.Feature...: Pure Kernel (password length 0-256 bytes)  
Guess.Base.....: File (/usr/share/wordlists/rockyou.txt)  
Guess.Queue.....: 1/1 (100.00%)  
Speed.#01.....: 40260 H/s (0.39ms) @ Accel:1024 Loops:1 Thr:1 Vec  
:4  
Recovered.....: 4/4 (100.00%) Digests (total), 4/4 (100.00%) Digests  
(new)  
Progress.....: 3072/14344385 (0.02%)  
Rejected.....: 0/3072 (0.00%)  
Restore.Point....: 0/14344385 (0.00%)  
Restore.Sub.#01..: Salt:0 Amplifier:0-1 Iteration:0-1  
Candidate.Engine.: Device Generator  
Candidates.#01...: 123456 → dangerous  
Hardware.Mon.#01.: Util: 3%  
Started: Thu Jul 16 10:28:23 2026  
Stopped: Thu Jul 16 10:28:56 2026
```

Figura 4 – Output di Hashcat con tutte le password individuate (4/4 hash recuperati)

3. Cracking con John the Ripper

Come secondo strumento è stato utilizzato John the Ripper, specificando esplicitamente il formato dell'hash (--format=raw-md5) e la wordlist RockYou come dizionario:

```
john --format=raw-md5 --wordlist=/usr/share/wordlists/rockyou.txt hash_dvwa.txt
```

Anche in questo caso, al primo tentativo John non ha trovato il file (poiché non era presente nella directory corrente), per cui è stato spostato nella cartella opportuna con il comando mv e rilanciato correttamente.

John the Ripper ha caricato i 4 hash MD5 (senza salt) e, sfruttando la wordlist RockYou, ha crackato tutte le password in pochi minuti, restituendo lo stesso risultato ottenuto con Hashcat: password, abc123, letmein, charley (associate rispettivamente agli utenti admin, gordonb, pablo e smithy).

4. Conclusioni

Entrambi gli strumenti, pur con sintassi e output differenti, sono giunti al medesimo risultato: tutte le password erano estremamente deboli e presenti nella wordlist RockYou, il che ha permesso un cracking rapido tramite semplice attacco a dizionario. L'esercitazione evidenzia l'importanza di adottare password complesse e non presenti in dizionari pubblici, per resistere a questo tipo di attacchi.